



SenseMail Application for iOS

Technical details

Encryption, keys and security

SenseMail is a secure mail application. It uses user-supplied passwords to protect the data. An encryption key is derived from a password with a "slow hash" function. There are three types of passwords:

- Password to launch the application. With this password the app encrypts all local data, such as settings, local image gallery, notes and the address book. The encryption key is derived from the password using 88.888 rounds of PBKDF2-SHA512 algorithm. 256 bytes is used for salt, 256 bytes for a key. The number 88.888 has been chosen so that it takes about 2 seconds on iPhone 4S to get the key. So, set your password 8-9 characters long and there should be a really serious reason to brute force it. In case you enter a wrong password the app wouldn't tell you anything - it will just start with an empty database. You can fill it with data and use two or more configs.
- Password to protect a message leaving your device. This password can be a unique string for every message, you just need to tell it to the recipient of the message. Again, the encryption key is derived from the password in 88.888 rounds. But the salt here is generated randomly in 88 rounds and is transmitted in the message subject. The message subject is encrypted with a key, derived from the receiver's e-mail address, so you'd better consider it insecure and don't write any sensitive information there.
- Password to protect a certificate. Every user can exchange certificates with another party and use it instead of a password. Use of a certificate drastically improves the security since it uses a full 256-bit key of random data whereas a password can't reach that degree of randomness. Each certificate is stored locally and is protected with a password. The encryption key is derived from the password in 3x88.888 rounds of PBKDF2.

All the data being encrypted are GZIP-deflated first (except for image attachments - they are already compressed and another compression will just consume more time and won't give anything to security), then the header and the footer of the compressed data are encrypted. After that the data is encrypted with AES-256. HMAC-SHA256 is added and everything is converted to BASE64.

There is an option to check mail in background in a certain period of time. To do so, the app needs to save the password to access settings. The saved password is stored locally encrypted with a pre-defined password. This is a serious security issue if an adversary gained a physical access to your device. In that case it is possible to reverse-engineer the password used to launch the app.

E-mail service provider

You can use any e-mail service provider that supports IMAP protocol. The connection is limited to TLS connections on port 993. The app will try to detect server settings once you entered your e-mail address.

For better user experience use GMAIL service since it has the most complete features such as message starring, IMAP folders detection and some others.

You can use several e-mail accounts, messages from every account will be shown in one list, sorted by date. You can access individual account through a menu.

Known limitations

Some information the app cannot hide. This is the data in message header, such as the IP-address from which the message is sent, time stamps, sender's and receiver's e-mail addresses. There might be some other data the e-mail service provider collects, but this is out of our control anyway. We do our best to protect the content of your message. If you really need a total control of your data you should consider running your own mail server.

Visit www.creepytwolabs.com (<http://www.creepytwolabs.com>) for more information.

Contacts

Should you have any questions about the application or need any further information, do not hesitate to contact us.



CreepyTwo Labs Ltd. info@creepytwolabs.com (mailto:info@creepytwolabs.com)